

Considerações Práticas sobre Análise de Riscos

Relembro, as etapas para o Gerenciamento de Riscos são: identificação, análise, planejamento e monitoramento. Após a etapa de identificação, temos uma lista de possíveis riscos. Com uma análise, temos uma lista de riscos priorizados. No planejamento são considerados planos de contingência e outras formas de prevenção. No monitoramento, podemos identificar mudanças nos riscos identificados e, caso necessário, realizar uma nova priorização, que pode levar a novas ações (SOMMERVILLE, 2019).

Vamos destacar a etapa de análise. Neste processo, temos como entrada uma lista de riscos e como saída uma lista de riscos priorizados. Porém, antes de utilizar uma avaliação para priorizar quais riscos são mais relevantes para um projeto, convém definir o que é risco. Quando dizemos que “isso é arriscado”, temos os conceitos de incerteza e probabilidade associados. Já quando dizemos que “isso é perigoso”, estamos pensando em outros conceitos como consequência e impacto. Ambas as frases são importantes quando definimos risco, pois ele está associado à probabilidades dos ataques e suas consequências. Ou seja, temos um risco maior se sua probabilidade de ocorrer for maior, e seu impacto for também maior. Podemos ter riscos moderados em casos intermediários, em que a probabilidade pode ser menor, porém o impacto maior, ou então se a probabilidade for maior, porém o impacto menor. De forma similar, podemos ter riscos menores se ambos probabilidade e impacto forem menores.

O fato é que a mensuração de risco, considerando a gravidade e o impacto, não é algo trivial, e não há forma fácil de se fazer isso.

É comum contar com experiências passadas da equipe para tentar classificar o risco de acordo com sua probabilidade e impacto. O impacto ou efeito pode ser: catastrófico (ameaça a sobrevivência do projeto), graves

(provocam atrasos significativos), toleráveis (dentro de contingências já previstas) ou insignificantes (sem impacto relevante para o projeto) (SOMMERVILLE, 2019).

Vamos entender estes conceitos, primeiro em um cenário envolvendo Internet das Coisas, Computação em Nuvem e Cibersegurança. Considere o cenário representado na Figura 1. Neste exemplo, temos uma casa inteligente da Alice com controle e monitoramento pelo celular de um chuveiro inteligente e uma lâmpada inteligente.

Figura 1 – Arquitetura de um exemplo em Internet das Coisas

IMAGEM

O celular da Alice é seu celular pessoal, com poucas travas de segurança e por isso com probabilidade média de sofrer um ataque. Por outro lado, o impacto de um ataque, se ele ocorrer, é alto, pois o celular possui controle de todos os equipamentos conectados em sua casa.

O servidor em nuvem pode ter probabilidade baixa e impacto alto associados, pois possui controle de todos os equipamentos, mas o fornecedor da solução de computação em nuvem pode implementar mais mecanismos preventivos de segurança.

Os dispositivos de Internet das Coisas podem ter probabilidade alta de serem atacados devido a poucos mecanismos de segurança nestes equipamentos. No caso da lâmpada, podemos ter um impacto médio devido a um mau funcionamento da lâmpada, ocasionado por um ataque. Porém o chuveiro, além de ter probabilidade alta, pode ter também um impacto alto, devido a queimaduras que um morador pode sofrer em caso de ataque cibernético.

Realizando a avaliação de risco, o lado da Alice possui risco médio, assim como o servidor em nuvem. A lâmpada possui um risco entre médio e alto, e o chuveiro possui risco alto.

Voltando para o contexto de gestão de projetos de desenvolvimento de software, temos alguns exemplos de avaliação de risco (SOMMERVILLE, 2019):

- Impossível de contratar pessoas com habilidades necessárias: probabilidade alta e efeitos catastróficos;

-

Mudanças em requisitos causam grande retrabalho: probabilidade moderada e efeitos graves;

- O tamanho do software foi subestimado: probabilidade alta e efeitos toleráveis.

Atividade Extra

Pesquise sobre alguns ataques no cenário de uma Casa Inteligente IoT, e realize uma avaliação para classificar os ataques de acordo com seu risco associado. Não se esqueça que, para cada ataque, é necessário entender sua probabilidade e impacto para mensurar o risco associado.

Referência Bibliográfica

SOMMERVILLE, I. **Engenharia de Software**, 10ª edição. Addison Wesley, 2019.